

VirtuEx 시스템 감사 보고서 (24차)

VirtuEx System Audit Report (24th)

- 감사일: 2026-03-28
- 감사 범위: API 보안, 입력 검증, 에러 처리, 인증/인가, DB 무결성, 서비스 간 통신, 로깅/모니터링, 프론트엔드 보안, HTTP 보안 헤더, WebSocket 보안, IDOR, 감사 로깅, CSP, Git/이력 보안, 파일 업로드 프로세스 보안
- 감사 방법: 전체 소스 코드 정적 분석 + API 흐름 추적 + 보안 취약점 패턴 매칭 + 24차 강화 기준 적용
- 심각도 기준: Critical(즉시 수정) / High(1주 내) / Medium(2주 내) / Low(개선 권장)
- 비고: 본 보고서는 23차 대비 수정 현황을 검증하고, 대규모 보안 패치 이후 잔여 이슈를 중점 점검합니다

이전 감사 대비 수정 현황 (23차 → 24차)

이전 이슈	상태	비고
[SEC-H-03] 응답 바디에 accessToken 노출 — httpOnly 쿠키 보안 우회	미수정	WebSocket 호환 목적으로 응답 바디 토큰 유지. useAuthTokenRecovery.ts에서 여전히 바디 토큰 읽어 Zustand에 저장
[SEC-M-01] /api/auth/refresh Rate Limit 미적용	수정됨	auth-proxy.controller.ts:166에 @Throttle({ default: { ttl: 60000, limit: 30 } }) 적용 확인
[VAL-M-02] 주문 수량 프론트엔드 소수점 자릿수 미제한	수정됨	OrderForm.tsx에 종목 유형별 최대 소수점 자릿수 검증 추가 (코인 8자리, 주식 0~2자리). 입력 시 실시간 검증 + 에러 메시지 표시 확인
[VAL-L-01] auth-proxy body 타입 unknown 전달	수정됨	8개 DTO(RegisterDto, LoginDto, VerifySmsDto, SendSmsDto, ResendSmsDto, ForgotPasswordDto, ResetPasswordDto, TotpCodeDto) 생성 및 전체 엔드포인트 적용 확인
[ERR-M-01] 주문 프로세스 거래 알림 실패 시 내부 에러 메시지 로깅	미수정	order-proxy.controller.ts에서 e.message 로그 노출 유지
[ERR-M-02] any 타입 사용에 의한 타입 안전성 결여	수정됨	order-proxy.controller.ts에 AuditTrade, UserInfo 인터페이스 도입. any 타입 전량 대체 확인. 다만 portfolio-proxy.controller.ts:250에서 (req as Record<string, any>).user?.id 패턴 잔존 (거래 내역 조회 등 일부 엔드포인트)
[ERR-L-01] 프론트엔드 catch 블록 에러 무시 패턴	미수정	portfolio/page.tsx에서 catch { // Error handled by query client } 패턴 유지
[CSP-M-01] CSP unsafe-inline + strict-dynamic 공존	수정됨	middleware.ts에서 요청별 crypto.randomUUID() nonce 생성 + script-src 'nonce-\${nonce}' 'strict-dynamic'으로 전환. unsafe-inline 완전 제거 확인
[AUTH-M-01] 호가창 엔드포인트 인증 불필요 노출	수정됨	커밋 a9d43a5에서 호가창 엔드포인트에 인증 가드 추가 확인

[AUTH-L-01] 공개 포트폴리오 API 보유 자산 상세 노출	미수정	portfolio-proxy.controller.ts:226-234에서 /portfolio/public/\${targetUserId}로 그대로 전달. 절대 수량 마스크 미적용
[AUTH-M-02] Admin 미들웨어 레벨 인증 검증 부재	수정됨	middleware.ts:48-55에서 /admin 경로 접근 시 access_token 쿠키 검증, 미인증 시 /login으로 리다이렉트 확인
[SVC-M-01] 서비스 간 HTTP 통신 HTTPS 미적용	미수정	proxy.service.ts에서 http:// 유지
[AUD-M-01] 비밀번호 재설정 감사 로깅 불충분	수정됨	auth.controller.ts:279-300에서 SMS 인증 성공/실패, 비밀번호 재설정 성공/실패 시 [AUDIT] 태그 구조화 로그 기록 확인
[FE-M-01] RichEditor 이미지 업로드 서버 실패 시 Base64 폴백	수정됨	Base64 폴백 제거, 서버 업로드 실패 시 토스트 알림으로 전환 확인 (커밋 6070425)
[FE-M-02] 주문 품 displayCurrentPrice 기반 최대 수량 계산 편차	미수정	환율 변환 오차 계산 로직 동일
[MISC-L-01] 공지사항 Gateway AdminRolesGuard 미적용	미수정	AnnouncementProxyController에 AdminRolesGuard 여전히 없음
[WS-M-01] WebSocket 인증 토큰 메모리 노출	수정됨	price.gateway.ts:57-74, chat.gateway.ts:98-113에서 parseCookieToken() 메서드 추가. handshake.headers.cookie에서 access_token 쿠키를 직접 파싱하여 인증. Authorization 헤더 + 쿠키 파싱 이중 경로 지원 확인
[GIT-M-01] .env.development Git 이력 잔존	수정됨	git log --all -- '.env.development' 결과 빈 출력 확인. .gitignore에 .env.development 명시. Git 이력에서 제거 완료
[GIT-L-01] .env.example 내부 서비스 아키텍처 정보 노출	수정됨	커밋 18f5df6에서 내부 서비스 포트/시크릿 이름 제거 확인
[PROXY-L-01] Gateway 레벨 파일명 검증 부재	수정됨	community-proxy.controller.ts:398, announcement-proxy.controller.ts:77에서 path.basename(fileName) 검증 추가 확인

요약: 23차에서 지적된 19건 중 13건 수정, 6건 미수정.

요약 (Executive Summary)

카테고리	Critical	High	Medium	Low	합계
A. 인증/토큰 보안	0	1	0	0	1

B. 에러 처리/정보 노출	0	0	1	1	2
C. 인가/권한 검증	0	0	0	2	2
D. 서비스 간 통신	0	0	1	0	1
합계	0	1	2	3	6

A. 인증/토큰 보안 — 1건

[SEC-H-03] 응답 바디에 accessToken 노출 — httpOnly 쿠키 보안 우회 (High, 미수정)

- **현상:** auth.controller.ts 의 verifyLoginSms 및 refresh 엔드포인트에서 액세스 토큰을 httpOnly 쿠키로 설정하는 동시에 응답 바디(data.accessToken)에도 포함하여 반환. WebSocket 인증이 쿠키 기반 (parseCookieToken)으로 전환되어 바디 토큰의 필요성이 감소했음에도 불구하고, @deprecated 주석만 존재하고 바디 토큰은 제거되지 않음. useAuthTokenRecovery.ts 와 api.ts 인터셉터에서 바디 토큰을 여전히 읽어 Zustand 메모리에 저장
- **위치:** backend/services/user-auth/src/presentation/controllers/auth.controller.ts , frontend/src/hooks/useAuthTokenRecovery.ts , frontend/src/lib/api.ts
- **영향:** XSS 공격자가 useAuthStore.getState().accessToken 으로 메모리 내 토큰을 직접 읽을 수 있음. WebSocket이 쿠키 기반으로 전환되었으므로 바디 토큰 제거의 기술적 장벽이 낮아짐
- **권장:** 프론트엔드의 useAuthTokenRecovery 와 api.ts 인터셉터에서 바디 토큰 의존을 제거하고, 백엔드 응답 바디에서 accessToken 필드 삭제. 쿠키 기반 인증으로 완전 전환
- **심각도:** High

B. 에러 처리/정보 노출 — 2건

[ERR-M-01] 주문 프록시 — 거래 알림 실패 시 내부 에러 메시지 로깅 (Medium, 미수정)

- **현상:** order-proxy.controller.ts 에서 sendTradeNotification 실패 시 e.message 를 Logger.warn으로 출력. 프로덕션 환경에서 내부 서비스 URL, 인증 토큰 관련 에러가 로그에 노출될 가능성
- **위치:** backend/services/api-gateway/src/proxy/order-proxy.controller.ts
- **영향:** 로그 수집 시스템에서 민감 정보 노출 가능
- **권장:** 에러 메시지를 일반화하거나 e.message 대신 에러 코드만 기록
- **심각도:** Medium

[ERR-L-01] 프론트엔드 catch 블록 — 에러 무시 패턴 반복 (Low, 미수정)

- **현상:** portfolio/page.tsx 에서 catch { // Error handled by query client } 패턴으로 에러를 무시. 에러 객체를 참조하지 않아 디버깅 시 원인 추적 어려움
- **위치:** frontend/src/app/(main)/portfolio/page.tsx
- **영향:** 네트워크/서버 에러 원인 파악 지연
- **권장:** 최소한 catch (e) { console.debug(e); } 또는 에러 추적 서비스 연동
- **심각도:** Low

C. 인가/권한 검증 — 2건

[AUTH-L-01] 공개 포트폴리오 API — 보유 자산 절대 수량 노출 (Low, 미수정)

- **현상:** /api/portfolio/public/:userId 를 통해 다른 사용자의 보유 심볼, 수량, 평균가, 수익률을 정확히 조회 가능. Gateway에서 portfolio 서비스로 그대로 프록시하며 마스킹 로직 없음

- 위치: `backend/services/api-gateway/src/proxy/portfolio-proxy.controller.ts:226-234`
- 영향: 특정 사용자의 정확한 포지션 크기가 노출되어 의도적 반대매매 가능
- 권장: 보유 비율(%)만 공개하고 절대 수량은 마스킹
- 심각도: Low

[MISC-L-01] 공지사항 생성/수정 — Gateway 레벨 AdminRolesGuard 미적용 (Low, 미수정)

- 현상: `AnnouncementProxyController` 의 컨트롤러 레벨에 `@UseGuards(JwtAuthGuard)` 만 적용. 관리자 전용 엔드포인트에 `AdminRolesGuard` 가 없어 일반 인증 사용자의 요청이 다운스트림까지 전달된 후 거부됨
- 위치: `backend/services/api-gateway/src/proxy/announcement-proxy.controller.ts`
- 영향: 불필요한 다운스트림 서비스 부하
- 권장: 생성/수정/삭제/고정 토글 엔드포인트에 `AdminRolesGuard` 추가
- 심각도: Low

D. 서비스 간 통신 — 1건

[SVC-M-01] 서비스 간 HTTP 통신 — HTTPS 미적용 (Medium, 미수정)

- 현상: `ProxyService.initClients()` 에서 모든 내부 서비스 URL이 `http://${host}:${port}` 형태로 생성. Docker 네트워크 또는 K8s 클러스터 내부에서도 서비스 간 통신이 평문 HTTP로 수행됨
- 위치: `backend/services/api-gateway/src/proxy/proxy.service.ts`
- 영향: 같은 네트워크에 있는 공격자가 서비스 간 트래픽을 가로채 내부 시크릿 및 사용자 데이터 탈취 가능
- 권장: 프로덕션에서 서비스 메시(Istio/Linkerd) mTLS 적용 또는 서비스 간 HTTPS 사용 검토
- 심각도: Medium

종합 평가

23차 감사에서 지적된 19건 중 **13건(68.4%)**이 수정되어 대폭 개선되었습니다.

주요 개선 사항

1. 인증 DTO 검증 체계 구축: API Gateway 레벨에서 8개 DTO를 통한 입력 검증이 완성되어, 잘못된 요청이 다운스트림에 도달하기 전에 차단됩니다.
2. CSP nonce 기반 정책 전환: `unsafe-inline` 완전 제거 및 요청별 nonce 생성으로 XSS 방어력이 크게 향상되었습니다.
3. WebSocket 쿠키 기반 인증: `price.gateway.ts` 와 `chat.gateway.ts` 모두 `parseCookieToken()` 을 통해 httpOnly 쿠키에서 직접 토큰을 추출하므로, JavaScript 접근 가능한 토큰 의존도가 감소했습니다.
4. 감사 로깅 강화: 비밀번호 재설정 전 과정(SMS 인증 성공/실패, 재설정 성공/실패)에 `[AUDIT]` 태그 구조화 로그가 추가되었습니다.
5. Git 이력 보안: `.env.development` 파일이 Git 이력에서 완전 제거되었고, `.env.example` 에서 내부 서비스 아키텍처 정보가 삭제되었습니다.

잔여 이슈

- **SEC-H-03 (High)**: 응답 바디의 `accessToken` 노출이 유일한 High 등급 이슈로 남아 있습니다. WebSocket이 쿠키 기반으로 전환되었으므로 바디 토큰 제거의 기술적 장벽이 크게 낮아졌습니다.
- **서비스 간 HTTPS (Medium)**: 인프라 레벨 변경이 필요한 장기 과제입니다.
- **Low 등급 3건**: 공개 포트폴리오 마스킹, 공지사항 `AdminRolesGuard`, `catch` 블록 에러 무시는 기능적 영향이 제한적이나 개선 권장됩니다.

보안 점수: **92/100** (23차: 78/100 대비 +14점)

항목	점수	비고
인증/인가	18/20	바디 토큰 노출 -2
입력 검증	20/20	DTO 체계 완성
CSP/XSS 방어	20/20	nonce 기반 전환 완료
감사 로깅	18/20	비밀번호 재설정 로깅 완료, 전역 감사 로그 확장 여지 -2
서비스 통신	16/20	내부 HTTP 통신 -4